

PASTA Worksheet – ABC Bank Mobile Banking Application

Organization

ABC Bank

Purpose

This PASTA (Process for Attack Simulation and Threat Analysis) worksheet analyzes potential cybersecurity threats and vulnerabilities affecting ABC Bank's mobile and online banking application. The goal is to identify risks and recommend controls to protect customer financial information, banking transactions, and system availability.

I. Define Business and Security Objectives

The ABC Bank mobile banking application should:

- Allow customers to securely create accounts, log in, and manage banking services online.
 - Enable customers to transfer funds, pay bills, and check account balances safely.
 - Protect customer financial data and personally identifiable information (PII).
 - Provide secure communication between customers and bank representatives.
 - Ensure payment processing and transactions are fast, reliable, and compliant with banking regulations.
 - Maintain customer trust by preventing fraud, data breaches, and unauthorized access.
 - Ensure continuous banking availability with minimal downtime.
-

II. Define the Technical Scope

The technical scope includes the systems, technologies, and services used by ABC Bank's online and mobile banking platforms.

Technologies and Components Reviewed

1. SQL Databases

SQL databases store:

- Customer account information

- Transaction histories
- Login credentials
- Payment records

These databases are high-risk targets because attackers may attempt SQL injection attacks to steal or manipulate sensitive banking data.

2. APIs (Application Programming Interfaces)

APIs connect:

- Mobile banking applications
- Payment gateways
- ATM systems
- Third-party financial services

Improperly secured APIs may expose customer data or allow unauthorized transactions.

3. Authentication Systems

The banking application uses:

- Usernames and passwords
- Online login systems
- Remote access services

Weak authentication systems increase the risk of account compromise.

4. Communication Channels

Customer communication occurs through:

- Mobile applications
- Web browsers
- Internal banking servers

If communications are not encrypted, attackers may intercept sensitive information.

III. Decompose the Application

Sample Data Flow Description

User Actions

1. Customer logs into the mobile banking app.
 2. Login credentials are sent securely to the authentication server.
 3. The server verifies customer information in the SQL database.
 4. Customers perform banking activities such as:
 - Fund transfers
 - Bill payments
 - Viewing balances
 5. Payment requests are processed through banking APIs and payment systems.
 6. Transaction details are stored in the bank database.
-

Key Components

- Mobile Banking Application
 - Web Banking Portal
 - Authentication Server
 - SQL Database Server
 - Payment Gateway APIs
 - Internal Banking Network
 - Customer Devices
-

IV. Threat Analysis

Potential Threats

1. SQL Injection Attacks

Attackers may exploit vulnerable input fields to:

- Access customer financial data
- Modify banking records

- Bypass authentication systems
-

2. Man-in-the-Middle (MITM) Attacks

Attackers may intercept unencrypted communication between:

- Customer devices
- Banking servers
- Payment systems

This could expose:

- Login credentials
 - Banking transactions
 - Payment information
-

3. Credential Theft

Cybercriminals may use:

- Phishing emails
- Fake login pages
- Malware

to steal customer usernames and passwords.

4. API Exploitation

Weak API security could allow attackers to:

- Access customer accounts
 - Perform unauthorized transactions
 - Extract sensitive banking information
-

5. Distributed Denial of Service (DDoS) Attacks

Attackers may overload banking systems with traffic, causing:

- Banking outages

- Customer service disruptions
 - Financial losses
-

V. Vulnerability Analysis

Identified Vulnerabilities

1. Unvalidated Input Fields

Poorly sanitized input fields may allow malicious SQL commands to be inserted into database queries.

Risk

- Data theft
 - Database manipulation
 - Unauthorized access
-

2. Weak Encryption Protocols

Weak or outdated encryption methods may expose:

- Customer credentials
- Payment information
- Banking transactions

Risk

Sensitive data may be intercepted during transmission.

3. Weak Password Practices

Customers and employees may use:

- Weak passwords
- Reused passwords

Risk

Increased likelihood of account compromise.

4. Insufficient API Security

APIs without:

- Proper authentication
- Rate limiting
- Access controls

may become attack entry points.

5. Lack of Security Monitoring

Without proper monitoring tools, cyberattacks may remain undetected for long periods.

VI. Attack Modeling

Sample Attack Scenario

Goal

Steal customer banking information.

Attack Path

1. Attacker identifies vulnerable login form.
 2. SQL injection payload is inserted into input field.
 3. Database returns unauthorized customer records.
 4. Attacker gains access to financial information.
 5. Stolen credentials are used for fraudulent banking transactions.
-

Additional Attack Scenario

Goal

Intercept customer banking transactions.

Attack Path

1. Attacker connects to unsecured public Wi-Fi.
2. Customer accesses online banking system.
3. Attacker intercepts unencrypted traffic.

4. Login credentials and banking details are stolen.
-

VII. Risk Analysis and Impact

Security Recommendations

1. Implement Input Validation and Parameterized Queries

This prevents SQL injection attacks by ensuring user input is safely processed.

Benefit

Protects customer and transaction databases.

2. Enforce Multifactor Authentication (MFA)

Require customers and employees to verify identities using:

- Passwords
- Authentication apps
- Verification codes

Benefit

Reduces unauthorized access risks.

3. Enforce TLS/SSL Encryption

Use strong encryption for:

- Mobile banking traffic
- Web sessions
- Payment processing systems

Benefit

Prevents Man-in-the-Middle attacks.

4. Conduct Regular Vulnerability Assessments

Perform:

- Vulnerability scanning

- Penetration testing
- Security audits

Benefit

Identifies and fixes security weaknesses before attackers exploit them.

5. Secure APIs

Implement:

- API authentication
- Access controls
- Rate limiting
- API monitoring

Benefit

Protects banking systems from unauthorized access.

6. Implement Security Monitoring and Logging

Use:

- Intrusion Detection Systems (IDS)
- Security Information and Event Management (SIEM)

Benefit

Detects suspicious activities quickly.

Conclusion

The PASTA assessment for ABC Bank identifies several cybersecurity threats affecting the bank's mobile and online banking systems, including SQL injection, MITM attacks, credential theft, and API exploitation.

By implementing stronger authentication, encryption, secure coding practices, and continuous security monitoring, the bank can significantly reduce cybersecurity risks, protect customer financial data, and maintain trust in its digital banking services.